
Application Assessment Report

Current state, health, technical debt, security and modernization analysis

Application	Live Test 09/29 B (APP-014)
Client	Example State Agency
Engagement	Application Portfolio Assessment
Version	v1.0 Final
Date	September 29, 2026
Classification	Confidential

Contents

Document control

1. Application summary
 - 1.1 Executive snapshot
 - 1.2 Key findings
 - 1.3 Immediate actions
2. Business context and process mapping
 - 2.1 Business purpose and ownership
 - 2.2 User community
 - 2.3 Business process map
 - 2.4 Business calendar and timing
 - 2.5 Business pain points and improvement opportunities
3. Technical profile
 - 3.1 Application classification
 - 3.2 Technology stack
 - 3.3 Licensing and contracts
 - 3.4 Configuration and customization
4. Architecture and integrations
 - 4.1 Architecture diagram
 - 4.2 Integration and data exchange inventory
 - 4.3 Dependency analysis
 - 4.4 Architecture observations
5. Data profile and reporting
 - 5.1 Data inventory
 - 5.2 Data quality and integrity
 - 5.3 Reports and outputs
 - 5.4 Analytics tooling
6. Application health and supportability
 - 6.1 Health scorecard
 - 6.2 End-of-life and supportability
7. Technical debt
 - 7.1 Technical debt summary
 - 7.2 Code quality indicators
 - 7.3 Technical debt register
 - 7.4 Architecture, infrastructure and process debt
 - 7.5 Remediation priorities
8. Security and vulnerabilities
 - 8.1 Security control assessment
 - 8.2 Vulnerability assessment summary
 - 8.3 Vulnerability register
 - 8.4 Unsupported and vulnerable components
 - 8.5 Regulatory and policy alignment
9. Risk and impact matrix
 - 9.1 Risk register
 - 9.2 Business impact of failure
 - 9.3 Heat map placement
10. Operational support and IT dependency

- 10.1 Support model
- 10.2 Support demand (trailing 24 months)
- 10.3 Dependency reduction opportunities
- 10.4 Knowledge concentration
- 11. User experience
 - 11.1 Usability assessment
 - 11.2 User experience improvement opportunities
- 12. Modernization options and recommendation
 - 12.1 Disposition options considered
 - 12.2 Options evaluation
 - 12.3 Recommendation
 - 12.4 Sequencing and timing
- 13. Evidence, open items and sign-off
 - 13.1 Stakeholder interviews
 - 13.2 Documents and evidence reviewed
 - 13.3 Assumptions and constraints
 - 13.4 Open items
 - 13.5 Review and acceptance
 - 13.6 Appendices

Rating scales and definitions

Recommendations in this report describe options and priorities for the client to act on; they are not a design or implementation commitment.

Scores in this report are measured on a 0 to 100 scale (100 = best) from itemised deductions and converted to the condition scale below: 90 or more is 1 – Excellent, 75 to 89 is 2 – Good, 55 to 74 is 3 – Fair, 35 to 54 is 4 – Poor, and below 35 is 5 – Critical. Every rating states the deductions behind it.

Standard rating scales

Score	Likelihood of failure or issue	Business impact	Condition (health dimensions)
1	Rare: not expected within 3 years	Minimal: workaround exists, no financial or compliance effect	Excellent: current, supported, well documented
2	Unlikely: possible within 3 years	Minor: internal inconvenience, short delay	Good: minor gaps, supported
3	Possible: plausible within 12 to 24 months	Moderate: delayed transactions or reports, manual rework	Fair: aging, partially supported, known gaps
4	Likely: expected within 12 months	Major: missed regulatory deadline, customers or constituents affected	Poor: near end of support, fragile, key-person dependent
5	Almost certain: occurring now or recurring	Severe: halted or incorrect core business operations, audit or legal exposure	Critical: unsupported, failing or unmaintainable

Risk score equals likelihood multiplied by impact (1 to 25). Scores of 15 and above are rated High, 8 to 14 Medium, and 7 and below Low.

Criticality tiers

Tier	Definition
Tier 1, Mission critical	Directly supports a core business function, financial transaction or regulatory obligation; outage tolerable for hours
Tier 2, Business essential	Supports a Tier 1 process or a regulated data collection; outage tolerable for days
Tier 3, Supporting	Internal analysis, convenience or reference use; outage tolerable for weeks

Document control

Field	Entry
Client	Example State Agency
Engagement	Application Portfolio Assessment
Application name	Live Test 09/29 B
Application ID	APP-014
Report version	v1.0 Final
Assessment period	2026-09-29 to 2026-09-29
Prepared by	Ledelsea Assessment Team

Field	Entry
Technical reviewer	Unknown
Business owner reviewer	Unknown
IT reviewer	Unknown
Classification	Confidential
Related applications (by ID)	None identified

Revision history

Version	Date	Author	Summary of changes
1.0	2026-09-29	Ledelsea Assessment Team	Assessment report issued

1. Application summary

This section gives client leadership a one-page view of the application, its condition and the recommended direction before the detailed analysis that follows.

1.1 Executive snapshot

Attribute	Entry
Purpose in one sentence	Calculates and posts monthly state aid payments to school districts and lets staff look up payment status.
Business area or program supported	School finance
Business value or volume supported	Unknown
Criticality tier	Tier 1
Overall health rating (Section 6)	2 – Good (1 is best, 5 is worst). This is the weighted average of the health scorecard in Section 6.1, where 5 of the 7 areas could be rated from the evidence.
Technical debt level (Section 7)	Low. 1 – Excellent. Maintainability scored 93 out of 100 (weakest file: 2_AIDPOST.rpgle, 79). Points were taken off because an outdated library or language feature is still in use (7 places, –49 points).
Open critical or high vulnerabilities (Section 8)	4 (1 critical, 3 high); register in 8.3
Highest risk score (Section 9)	20, High (R-014-01, 3_district_aid_lookup.html)
End-of-life exposure	jQuery 1.4.2 (unsupported)
Recommended disposition (Section 12)	Re-platform: Upgrade the out-of-date parts to supported versions, changing code only where needed.
Recommended timing	Short term, 0 to 12 months

1.2 Key findings

In short: Live Test 09/29 B is in good overall condition (2 on a scale where 1 is best and 5 is worst), but it has serious security problems and relies on technology the vendor no longer supports. The recommended direction is to re-platform: upgrade the out-of-date parts to supported versions, changing code only where needed (Section 12).

Security (Section 8). The review found 1 critical, 2 high and 7 medium issues. The most serious: a password or key is written directly into the code (hard-coded credential) (critical); data is sent without encryption (plain HTTP instead of HTTPS/TLS) (high); and sensitive data such as a password is sent in the web address (GET request) (high). Because the application handles personal data, a breach would expose personal records, so these issues are rated one level higher than they otherwise would be. Security is rated 5 – Critical (it scored 25 out of 100).

Supportability (Section 6.2). jQuery 1.4.2 is past the vendor's end of support. Unsupported software no longer receives security fixes, so its known weaknesses stay open until it is upgraded or replaced.

Risk (Section 9). The highest risk is R-014-01, 3_district_aid_lookup.html: 20 of 25, which is High. Likelihood 5 of 5, because its weakest area (security) scored 0 out of 100. Impact 4 of 5: it handles personal data (a default until the business owner rates it). Risk score $5 \times 4 = 20$ of 25.

Effort (Section 12.4). The recommended work is estimated at 4.0–12.5 person-weeks, about 1–3 months for one developer. The first items are quick security fixes that can be made before any wider modernization decision (Section 1.3).

1.3 Immediate actions

These problems should be fixed now, before any decision on modernization, because they expose data or users today:

#	Condition	Recommended interim action	Owner	Urgency
1	Encrypt connections (3_district_aid_lookup.html). Why it matters: it can be read or changed on the network.	Enable TLS for service endpoints and database connections (Encrypt=True, https).	IT	Within 90 days
2	Remove hard-coded credentials (3_district_aid_lookup.html). Why it matters: anyone who can read the code can use it, and it can't be changed without a code release.	Move secrets to a vault or protected configuration and rotate every exposed password.	IT	Within 30 days
3	Harden UI security (3_district_aid_lookup.html). Why it matters: web addresses are stored in browser history and server logs.	POST sensitive forms, add anti-forgery tokens, mask passwords and personal identifiers, remove trusted values from hidden fields.	IT	Within 90 days

2. Business context and process mapping

This section establishes why the application exists, who depends on it, and how it fits into the business calendar, so that technical findings can be weighed against real business consequences.

2.1 Business purpose and ownership

Attribute	Entry
Business capability supported	Calculates and posts monthly state aid payments to school districts and lets staff look up payment status.
Regulatory, contractual or policy basis	Unknown
Business owner	Unknown
Subject matter experts	Unknown
Year introduced	Unknown
Known drivers of change	Unknown

2.2 User community

User group	Internal or external	Approximate number of users	Access method	Frequency and peak periods
Business users of the application screens	Unknown	Unknown	4 screen(s): 3_district_aid_lookup, AIDDSP, AIDSCR, DISTRICT AID INQUIRY (AIDI) — Minnesota	Unknown

2.3 Business process map

The screen flow below is drawn from the screens and navigation in the source. Business actors, manual steps and handoffs outside the application are to be mapped with stakeholders (open item).

User flow — Live Test 09/29 B



Figure 2. Current-state screen flow for Live Test 09/29 B, drawn from the screens and navigation in the source.

Step	Actor	Activity	Manual or automated	Inputs	Outputs	Pain point observed
No process steps could be derived from the source; to be mapped with stakeholders.						

2.4 Business calendar and timing

Cycle or event	Timing	Dependency on this application	Consequence if unavailable
No scheduled cycles were identified in the source; business calendar to be confirmed with the business owner.			

2.5 Business pain points and improvement opportunities

Stakeholder interviews were not part of this review, so pain points are not recorded in stakeholders' words (open item).

Issues observable in the application itself:

Image without text alternative: 3_district_aid_lookup.html:29

Form field without a label: 3_district_aid_lookup.html:36

Form field without a label: 3_district_aid_lookup.html:42

Form field without a label: 3_district_aid_lookup.html:53

Form field without a label: 3_district_aid_lookup.html:54

Form field without a label: 3_district_aid_lookup.html:55

3. Technical profile

This section inventories every technical component of the application with its version and vendor support status, which forms the evidence base for the end-of-life and supportability ratings in Section 6.

3.1 Application classification

Attribute	Entry
Application type	Batch process, Online screens
Build origin	Custom built (application source code is maintained by the client)
Legacy lineage	3 of 5 files are mainframe or midrange languages (Assembler, COBOL, RPG)
Deployment model	Unknown
Environments	Unknown
Source code location and control	Unknown
Size indicators	454 lines in 5 files; 2 program(s), 2 screen(s), 3 table(s), 8 data store(s)

3.2 Technology stack

Layer	Technology and version	Vendor	Mainstream support end	Extended support end	Status
Presentation / UI	jQuery 1.4.2	OpenJS Foundation	Unknown	Unknown	Unsupported
Application framework	None identified in the source				
Programming languages	None identified in the source				
Third-party libraries and components	None identified in the source				
Database	IBM IMS (DB/DC) (version not confirmed)	IBM	Unknown	Unknown	Supported
Reporting	None identified in the source				
Batch and scheduling	None identified in the source				

Layer	Technology and version	Vendor	Mainstream support end	Extended support end	Status
Web and application server	Unknown				
Operating system	IBM i (version not confirmed)	IBM	Unknown	Unknown	Version not confirmed
Identity and authentication	Unknown				
Infrastructure	Unknown				

3.3 Licensing and contracts

Product	License model	Quantity	Annual cost	Renewal date	Contract owner
Unknown					

3.4 Configuration and customization

1 hard-coded value(s) were found in the source, including: Hard-coded credential: 3_district_aid_lookup.html:8.

Where routine policy or rate changes require a code change, the item appears in the technical debt register (7.3).

4. Architecture and integrations

This section provides the visual architecture map for the application, together with a complete inventory of the integrations and data exchanges that connect it to the rest of the portfolio.

4.1 Architecture diagram

The architecture below is drawn from the confirmed components in Section 3, in the standard layer order so it can be read alongside other application reports.

Architecture overview — Live Test 09/29 B • verdict: Replatform

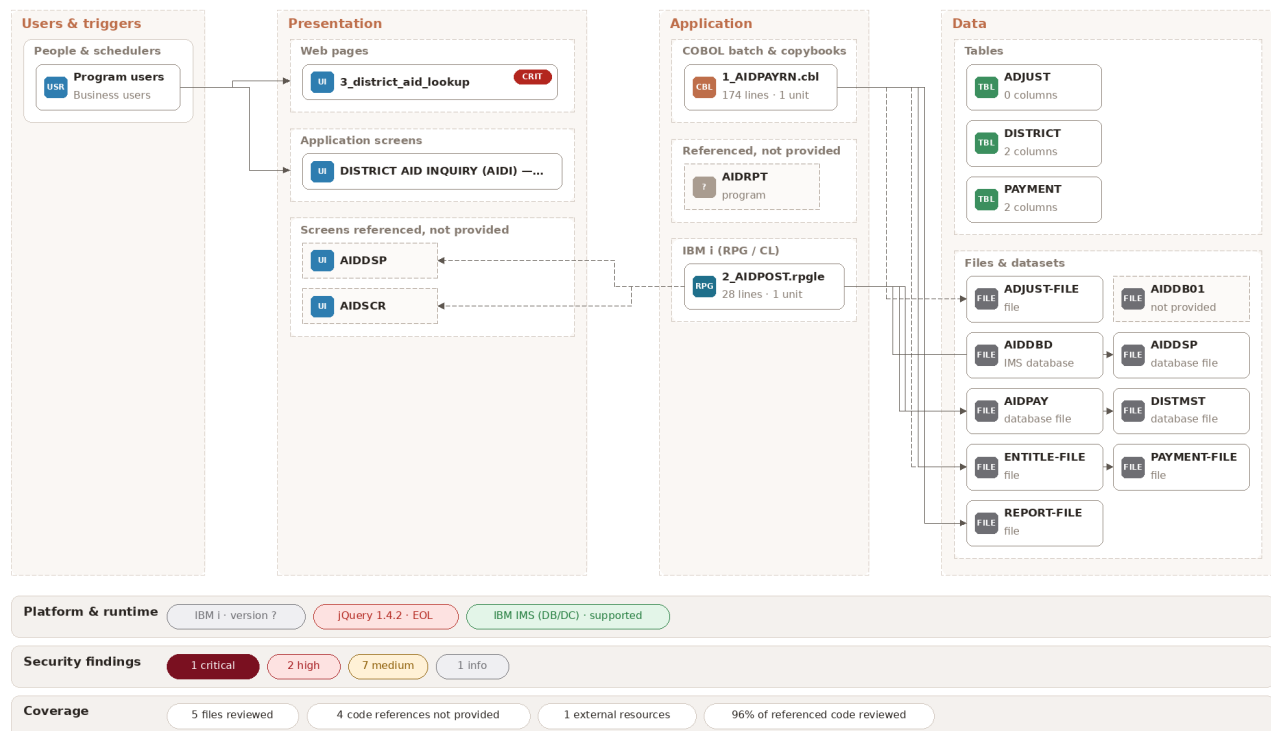


Figure 1. Logical architecture of Live Test 09/29 B: layers, components and the systems and data it touches.

View	What it must show	Status
A. Logical architecture	Layers, modules and business functions, as in the reference layout	Complete (Figure 1)
B. Deployment (physical) architecture	Servers, environments, network zones, hosting location, disaster recovery arrangement	Pending: hosting and network detail not available
C. Integration context	This application at the center with every upstream and downstream system, labeled with interface IDs from 4.2	Complete (Figure 3)
D. Data flow	Movement of key data entities from source to report, including manual handoffs and spreadsheet steps	Complete (Figure 4)

View	What it must show	Status
E. Portfolio position	Where the application sits in the overall application portfolio map	Pending: requires the portfolio inventory

Context — Live Test 09/29 B

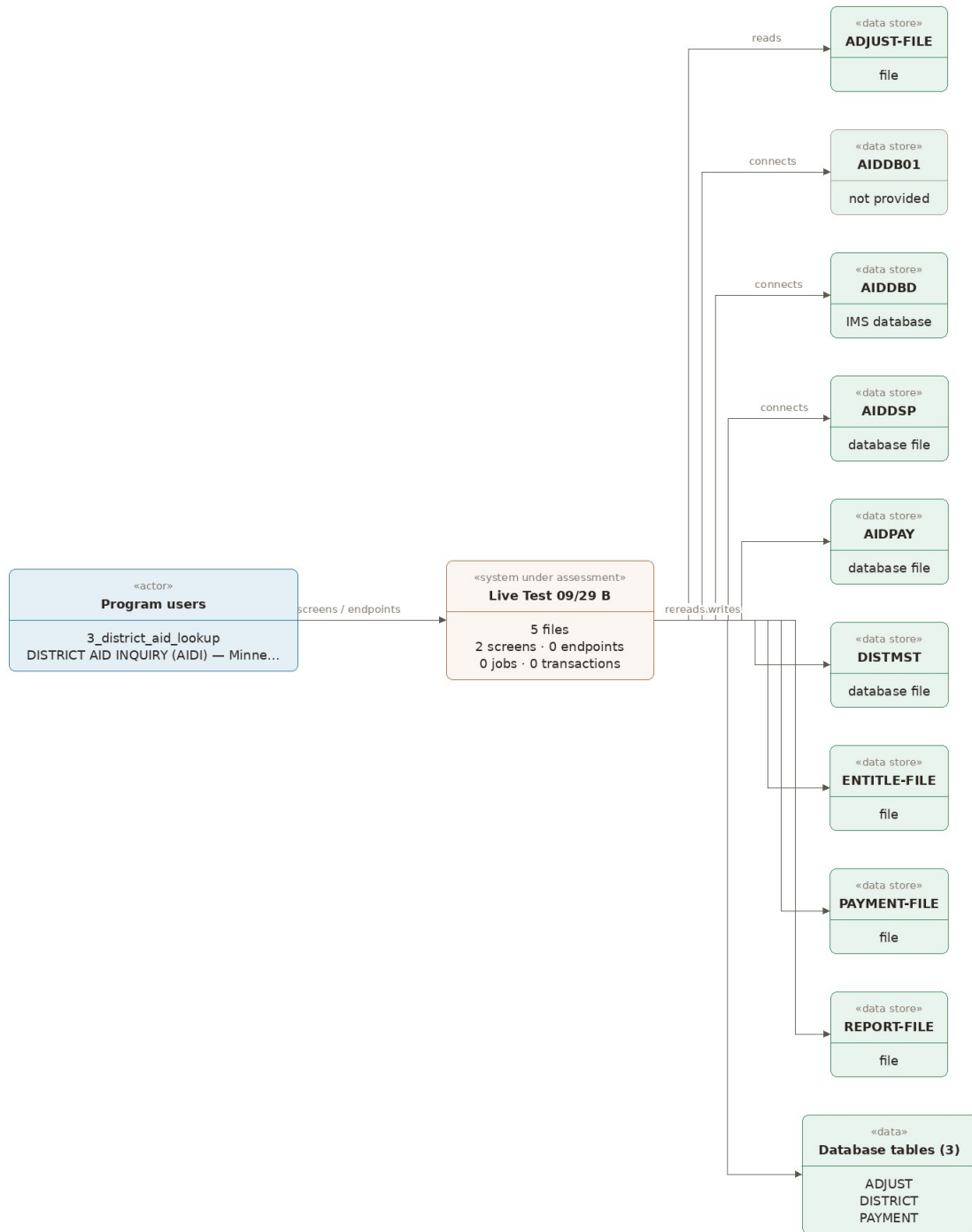


Figure 3. Integration context: the application with every upstream and downstream system and data store. Validation with the IT owner: pending.

Data model — Live Test 09/29 B

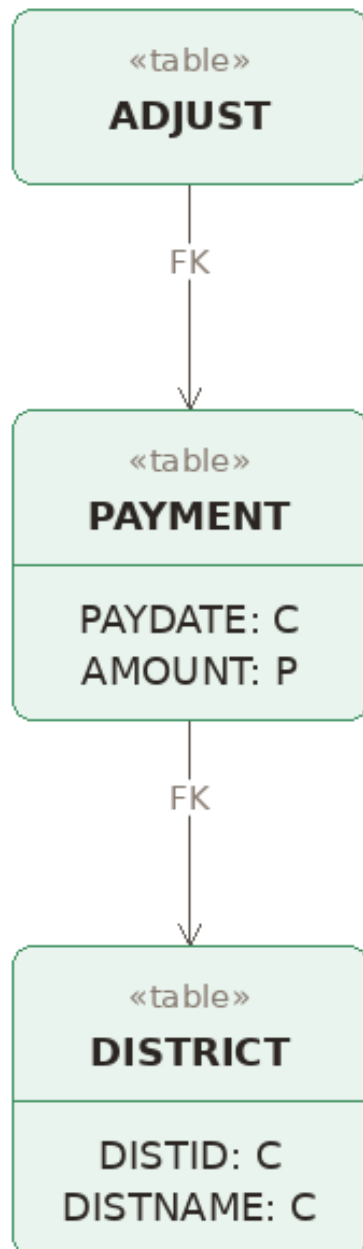


Figure 4. Data model: tables, columns and keys used by the application. Validation with the IT owner: pending.

4.2 Integration and data exchange inventory

Interface ID	Direction	Connected system (APP ID if in scope)	Data exchanged	Method	Format	Frequency and trigger	Owner	Failure handling	Documented
INT-014-01	Inbound	ADJUST-FILE	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-02	Unknown	AIDDBD	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-03	Unknown	AIDDSP	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-04	Bidirectional	AIDPAY	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-05	Inbound	DISTMST	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-06	Inbound	ENTITLE-FILE	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-07	Outbound	PAYMENT-FILE	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No
INT-014-08	Outbound	REPORT-FILE	Unknown	File or dataset	Fixed width	Unknown	Unknown	Unknown	No

4.3 Dependency analysis

- **Systems this application depends on:** AIDDB01
- **Systems that depend on this application:** Unknown
- **Shared components:** ADJUST, DISTRICT, PAYMENT
- **Hidden or informal dependencies:** programs referenced but not provided: AIDRPT, AIDDSP, AIDSCR

4.4 Architecture observations

Coupling is rated 1 (Excellent): 1 – Excellent. Dependencies scored 100 out of 100. No problems were found.

5. Data profile and reporting

This section documents what data the application owns, how trustworthy it is, and which reports depend on it, including external reports that any modernization option must account for.

5.1 Data inventory

Data entity	System of record (Y/N)	Approximate volume	Retention requirement	Data classification	Contains personal or regulated data
ADJUST	Unknown	Unknown	Unknown	Restricted	Personal data
DISTRICT	Unknown	Unknown	Unknown	Restricted	Personal data
PAYMENT	Unknown	Unknown	Unknown	Restricted	Personal data
ADJUST-FILE (file)	Unknown	Unknown	Unknown	Internal	Unknown

Data entity	System of record (Y/N)	Approximate volume	Retention requirement	Data classification	Contains personal or regulated data
AIDDB01 (file)	Unknown	Unknown	Unknown	Internal	Unknown
AIDDBD (file)	Unknown	Unknown	Unknown	Internal	Unknown
AIDDSP (file)	Unknown	Unknown	Unknown	Internal	Unknown
AIDPAY (file)	Unknown	Unknown	Unknown	Internal	Unknown
DISTMST (file)	Unknown	Unknown	Unknown	Internal	Unknown
ENTITLE-FILE (file)	Unknown	Unknown	Unknown	Internal	Unknown
PAYMENT-FILE (file)	Unknown	Unknown	Unknown	Internal	Unknown
REPORT-FILE (file)	Unknown	Unknown	Unknown	Internal	Unknown

5.2 Data quality and integrity

Dimension	Rating (1 to 5)	Evidence and observations
Accuracy	Not rated	Requires access to production data; not part of this review.
Completeness	Not rated	Requires access to production data; not part of this review.
Timeliness	Not rated	Requires access to production data; not part of this review.
Consistency across systems	Not rated	Requires access to production data; not part of this review.
Validation controls	Not rated	Requires access to production data; not part of this review.
Data lineage and documentation	Not rated	Requires access to production data; not part of this review.

5.3 Reports and outputs

Report ID	Report name	Audience	Tool	Frequency	Regulatory or contractual requirement	Manual effort to produce	Recommended future state
None identified in the material reviewed.							

5.4 Analytics tooling

No analytical or statistical tooling was identified in the source reviewed.

6. Application health and supportability

This section produces the overall health rating for the application. Each dimension is scored on the 1 to 5 condition scale, and the overall rating is the weighted average shown in the final row.

6.1 Health scorecard

Dimension	Weight	Score (1 to 5)	Weighted score	Evidence
Technology currency and vendor support	20%	2	0.40	Supportability scored 87 out of 100 (weakest file: 3_district_aid_lookup.html, 65). Points were taken off because jQuery 1 is past the vendor's end of support (end of life) (2 places, -36.5 points); and few people still have the skills to maintain this technology (3 places, -30 points).
Code quality and maintainability	15%	1	0.15	Maintainability scored 93 out of 100 (weakest file: 2_AIDPOST.rpgle, 79). Points were taken off because an outdated library or language feature is still in use (7 places, -49 points). Complexity scored 100 out of 100. No problems were found.
Stability and reliability	15%	1	0.15	Code health scored 99 out of 100 (weakest file: 2_AIDPOST.rpgle, 88). Points were taken off because it calls programs that were not provided for this review (-12 points); and no compiler for this language was available to confirm the file compiles (-5 points).
Performance and scalability	10%	Not rated	Excluded	Not rated: no evidence for this dimension in the material reviewed (open item).
Security posture	15%	5	0.75	Security scored 25 out of 100 (weakest file: 3_district_aid_lookup.html, 0). Points were taken off because a published security weakness (CVE) exists in jQuery 1.4.2 (5 places, -35 points); a password or key is written directly into the code (hard-coded credential) (-25 points); and 6 smaller issue(s) (-76 points).
Documentation and knowledge	10%	Not rated	Excluded	Not rated: no evidence for this dimension in the material reviewed (open item).
Business fit and adaptability	15%	1	0.15	Dependencies scored 100 out of 100. No problems were found.
Overall health rating	100%	2	2.0	2.0 – Good. The weighted average of the 5 areas that could be rated; the weights of the 2 unrated areas are left out, so the total is taken over 80%.

6.2 End-of-life and supportability

Component	Current version	End of mainstream support	End of extended support	Months remaining from assessment date	Upgrade path available	Notes
jQuery	1.4.2	Not published	Not published		Yes	script / library reference
IBM IMS (DB/DC)	Not confirmed	Not published	Not published		Not applicable	IMS 15 is supported; hierarchical DL/I data and MFS screens are scarce skills. Confirm the

7. Technical debt

This section identifies the shortcuts, outdated constructs and structural weaknesses that make the application harder and more expensive to change, and estimates the effort needed to remediate them.

7.1 Technical debt summary

Attribute	Entry
Overall technical debt level	Low. 1 – Excellent. Maintainability scored 93 out of 100 (weakest file: 2_AIDPOST.rpgle, 79). Points were taken off because an outdated library or language feature is still in use (7 places, –49 points).
Dominant debt categories	Code
Estimated total remediation effort	Included in the roadmap total of 4.0–12.5 person-weeks
Effect on delivery	An outdated library or language feature is still in use (3_district_aid_lookup.html); it makes changes riskier and blocks upgrades.
Trend	Not measurable from a single point-in-time review

7.2 Code quality indicators

Indicators below are measured from the source code provided for this review; indicators that need a running build or test suite are marked not measured.

Indicator	Measured value	Acceptable threshold	Tool or method	Observation
Lines of code (by language)	COBOL: 174, UI screen: 124, HTML: 115, RPG: 28, Assembler: 13	Not applicable	Source code review	
Average and maximum cyclomatic complexity	average 4.6, maximum 13 (1_AIDPAYRN.cbl)	Under 15 per routine	Decision-point count per file	Within threshold
Code duplication	Not measured	Under 5%		Not assessed in this review
Maintainability rating or code smells	1 (Excellent)	2 (Good) or better	Technical debt score	93/100; deductions in 7.1
Automated test coverage	0% (no automated tests found in the source)	60% or higher	Source code review	No test suite provided
Outdated third-party dependencies	1	0	Version and support-date review	
Dead or unused code	Not measured			Not assessed in this review
Share of machine-translated or generated legacy code	0%	Not applicable	Source code review	
Hard-coded values (rates, paths, credentials, dates)	1	0	Source code review	Hard-coded credential: 3_district_aid_lookup.html:8

7.3 Technical debt register

Debt ID	Description	Category	Root cause	Impact on operations and change	Remediation approach	Estimated effort	Priority
TD-014-01	An outdated library or language feature is still in use: legacy construct: jQuery 1.4.2 (known XSS issues before 3.5) (3_district_aid_lookup.html)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium

Debt ID	Description	Category	Root cause	Impact on operations and change	Remediation approach	Estimated effort	Priority
TD-014-02	An outdated library or language feature is still in use: legacy construct: doctype DTD HTML 4.01 Transitional (3_district_aid_lookup.html)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium
TD-014-03	An outdated library or language feature is still in use: legacy construct: QCMDEXC command strings (2_AIDPOST.rpgle)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium
TD-014-04	An outdated library or language feature is still in use: legacy construct: RPG cycle / indicators (*INxx) (2_AIDPOST.rpgle)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium
TD-014-05	An outdated library or language feature is still in use: legacy construct: fixed-form RPG (column-sensitive) (2_AIDPOST.rpgle)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium
TD-014-06	An outdated library or language feature is still in use: legacy construct: 3270 terminal (4_aidinq_3270_SCREEN.html)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium
TD-014-07	An outdated library or language feature is still in use: legacy construct: IMS hierarchical database (AIDDBD-live.dbd)	Code	Library or construct not upgraded	It makes changes riskier and blocks upgrades (~7 maintainability points)	Upgrade or replace	M	Medium

7.4 Architecture, infrastructure and process debt

Skills: few people still have COBOL/CICS; RPG / IBM i; and mainframe assembler skills, so support depends on a small, shrinking pool of in-house staff or vendors.

Release automation, environment parity and batch dependency documentation could not be assessed and are open items.

7.5 Remediation priorities

Quick wins to reduce risk now, independent of modernization: Encrypt connections; Remove hard-coded credentials; Harden UI security.

Because the recommended disposition (Re-platform) keeps the current code, every item in 7.3 can be fixed directly.

8. Security and vulnerabilities

This section assesses the application's security controls and known vulnerabilities so that modernization options address them rather than carrying them forward. Exploitable detail such as hostnames, IP addresses and proof-of-concept steps belongs in the restricted appendix, not in the body of this report.

8.1 Security control assessment

Control area	Current state	Gap identified	Rating (1 to 5)
Authentication (SSO, MFA, application-managed passwords)	1 issue(s): The password box shows the password as it is typed.	Anyone nearby can read it.	3 – Fair: the most serious issue here is medium
Authorization and role-based access	Unknown	Not assessed	Not rated: this can't be seen in the code
Privileged and service account management	Unknown	Not assessed	Not rated: this can't be seen in the code
Secrets management (credentials in code, config files, scripts)	1 issue(s): A password or key is written directly into the code (hard-coded credential).	Anyone who can read the code can use it, and it can't be changed without a code release.	5 – Critical: the most serious issue here is critical
Encryption in transit	1 issue(s): Data is sent without encryption (plain HTTP instead of HTTPS/TLS).	It can be read or changed on the network.	4 – Poor: the most serious issue here is high
Encryption at rest	No issues found in the source reviewed	None identified	2 – Good: nothing found in the code; not yet confirmed on the running system
Input validation and output encoding	2 issue(s): User input is written into the web page without being made safe (cross-site scripting, XSS).	An attacker could run their own script in a user's browser.	3 – Fair: the most serious issue here is medium

Control area	Current state	Gap identified	Rating (1 to 5)
Audit logging and monitoring	Unknown	Not assessed	Not rated: this can't be seen in the code
Patch management	5 issue(s): A published security weakness (CVE) exists in jQuery 1.4.2.	Attackers know about it and fixes exist.	3 – Fair: the most serious issue here is medium
Secure development practices	Unknown	Not assessed	Not rated: this can't be seen in the code
Backup, recovery and resilience	Unknown	Not assessed	Not rated: this can't be seen in the code
Third-party and vendor risk	5 issue(s): A published security weakness (CVE) exists in jQuery 1.4.2.	Attackers know about it and fixes exist.	3 – Fair: the most serious issue here is medium

8.2 Vulnerability assessment summary

Assessment type	Tool	Date performed	Scope	Critical	High	Medium	Low
Infrastructure and OS review	Not performed		Not in scope				
Web application review (DAST)	Not performed		Not in scope				
Static code analysis (SAST)	Source code review	2026-09-29	5 files	1	3	3	0
Software composition analysis (third-party libraries)	Version and CVE review	2026-09-29	3 components	0	0	5	0
Database configuration review	Not performed		Not in scope				
Penetration test (if available)	Not performed		Not in scope				

8.3 Vulnerability register

Vuln ID	Affected component	CVE or CWE reference	CVSS score	Severity	Exposure	Exploit known (Y/N)	Recommended remediation	Owner	Target date	Status	Restricted detail ref
VUL-014-01	3_district_aid_lookup.html :8	CWE-798	Not scored	Critical	Unknown	N	Change the password and move it to a secrets store	IT	2026-10-29	Open	Appendix D
VUL-014-02	3_district_aid_lookup.html :6	CWE-319	Not scored	High	Unknown	N	Switch the connection to HTTPS (TLS 1.2 or later)	IT	2026-12-28	Open	

Vuln ID	Affected component	CVE or CWE reference	CVSS score	Severity	Exposure	Exploit known (Y/N)	Recommended remediation	Owner	Target date	Status	Restricted detail ref
VUL-014-03	3_district_aid_lookup.html:6	CWE-319	Not scored	High	Internet facing	N	Load everything over HTTPS	IT	2026-12-28	Open	
VUL-014-04	3_district_aid_lookup.html:32	CWE-598	Not scored	High	Internet facing	N	Send it in the request body (POST)	IT	2026-12-28	Open	
VUL-014-05	3_district_aid_lookup.html	CVE-2012-6708, CWE-1395	Not scored	Medium	Unknown	Y	Upgrade to a fixed version	IT	2027-03-28	Open	
VUL-014-06	3_district_aid_lookup.html	CVE-2015-9251, CWE-1395	Not scored	Medium	Unknown	Y	Upgrade to a fixed version	IT	2027-03-28	Open	
VUL-014-07	3_district_aid_lookup.html	CVE-2019-11358, CWE-1395	Not scored	Medium	Unknown	Y	Upgrade to a fixed version	IT	2027-03-28	Open	
VUL-014-08	3_district_aid_lookup.html	CVE-2020-11022, CWE-1395	Not scored	Medium	Unknown	Y	Upgrade to a fixed version	IT	2027-03-28	Open	
VUL-014-09	3_district_aid_lookup.html	CVE-2020-11023, CWE-1395	Not scored	Medium	Unknown	Y	Upgrade to a fixed version	IT	2027-03-28	Open	
VUL-014-10	3_district_aid_lookup.html:61	CWE-549	Not scored	Medium	Internet facing	N	Use a masked password field	IT	2027-03-28	Open	
VUL-014-11	3_district_aid_lookup.html:12	CWE-79	Not scored	Medium	Unknown	N	Encode everything written to the page; avoid innerHTML and document.write	IT	2027-03-28	Open	
VUL-014-12	3_district_aid_lookup.html:17	CWE-79	Not scored	Medium	Unknown	N	Encode everything written to the page; avoid innerHTML and document.write	IT	2027-03-28	Open	

What these findings mean, in plain terms:

- VUL-014-01: a password or key is written directly into the code (hard-coded credential). Why it matters: anyone who can read the code can use it, and it can't be changed without a code release. Fix: move it to a secure secrets store and change the password.
- VUL-014-02: data is sent without encryption (plain HTTP instead of HTTPS/TLS). Why it matters: it can be read or changed on the network. Fix: switch the connection to HTTPS (TLS 1.2 or later).
- VUL-014-03: part of the page is loaded over unencrypted HTTP (mixed content). Why it matters: that part can be tampered with on the network. Fix: load everything over HTTPS.
- VUL-014-04: sensitive data such as a password is sent in the web address (GET request). Why it matters: web addresses are stored in browser history and server logs. Fix: send it in the request body (POST).

- VUL-014-05 to VUL-014-09: a published security weakness (CVE) exists in jQuery 1.4.2. Why it matters: attackers know about it and fixes exist. Fix: upgrade to a fixed version.
- VUL-014-10: the password box shows the password as it is typed. Why it matters: anyone nearby can read it. Fix: use a masked password field.
- VUL-014-11 and VUL-014-12: user input is written into the web page without being made safe (cross-site scripting, XSS). Why it matters: an attacker could run their own script in a user's browser. Fix: encode everything written to the page; avoid innerHTML and document.write.

8.4 Unsupported and vulnerable components

jQuery 1.4.2: unsupported. Compensating controls: unknown (open item).

8.5 Regulatory and policy alignment

Requirement	Applies (Y/N)	Compliance status	Notes
Client information security policy and standards	Y	Not assessed	Unknown
Security framework in use (e.g., NIST CSF, NIST SP 800-53, ISO 27001, CIS Controls)	Y	Partial	NIST SP 800-53 controls referenced by the findings in 8.3
Data privacy obligations (e.g., HIPAA, FERPA, GDPR, CCPA, state data practices law)	Y	Partial	FERPA: personal data is handled; see 8.3
Payment card data (PCI DSS)	N	Not assessed	
Records retention schedule	Unknown	Not assessed	
Open internal or external audit findings	Unknown	Not assessed	

9. Risk and impact matrix

This section consolidates the risks identified in Sections 3 through 8 into a single scored register, which is aggregated across all applications to produce the portfolio risk and impact matrix.

9.1 Risk register

Risk ID	Risk description	Category	Likelihood (1 to 5)	Impact (1 to 5)	Score	Rating	Existing mitigation	Recommended mitigation
R-014-01	3_district_aid_lookup.html : Runs on an end-of-life runtime with a supported successor	Technology	5	4	20	High	Unknown	Replatform: Upgrade the out-of-date parts to supported versions, changing code only where needed.
R-014-02	2_AIDPOST.rpgle: no serious weakness found; every area scored fair or better	Technology	1	4	4	Low	Unknown	Retain: Keep the application as it is, with routine maintenance only.
R-014-03	1_AIDPAYRN.cbl: no serious weakness found; every area scored fair or better	Technology	1	4	4	Low	Unknown	Retain: Keep the application as it is, with routine maintenance only.
R-014-04	4_aidinq_3270_SCREEN.html: no serious weakness found; every area scored fair or better	Security	1	3	3	Low	Unknown	Retain: Keep the application as it is, with routine maintenance only.
R-014-05	AIDDBD-live.dbd: no serious weakness found; every area scored fair or better	Technology	1	2	2	Low	Unknown	Retain: Keep the application as it is, with routine maintenance only.

Why each risk is rated as it is:

- R-014-01 (3_district_aid_lookup.html): Likelihood 5 of 5, because its weakest area (security) scored 0 out of 100. Impact 4 of 5: it handles personal data (a default until the business owner rates it). Risk score $5 \times 4 = 20$ of 25.
- R-014-02 (2_AIDPOST.rpgle): Likelihood 1 of 5, because its weakest area (supportability) scored 88 out of 100. Impact 4 of 5: it writes program data (a default until the business owner rates it). Risk score $1 \times 4 = 4$ of 25.
- R-014-03 (1_AIDPAYRN.cbl): Likelihood 1 of 5, because its weakest area (supportability) scored 90 out of 100. Impact 4 of 5: it writes program data (a default until the business owner rates it). Risk score $1 \times 4 = 4$ of 25.

- R-014-04 (4_aidinq_3270_SCREEN.html): Likelihood 1 of 5, because its weakest area (security) scored 100 out of 100. Impact 3 of 5: it user- or job-facing entry point (a default until the business owner rates it). Risk score $1 \times 3 = 3$ of 25.
- R-014-05 (AIDDBD-live.dbd): Likelihood 1 of 5, because its weakest area (supportability) scored 90 out of 100. Impact 2 of 5: it supporting component (a default until the business owner rates it). Risk score $1 \times 2 = 2$ of 25.

9.2 Business impact of failure

Scenario	Affected users and business functions	Maximum tolerable outage	Current workaround	Estimated consequence
Complete outage during a peak business cycle	Unknown	Unknown	Unknown	Delayed service; see the business calendar (2.4)
Processing or calculation error undetected	5 files of business logic	Not applicable	None identified in the source	Incorrect outputs and recovery effort
Security breach or data exposure	Personal data	Not applicable	Unknown	Notification obligations and legal exposure
Loss of key technical staff	Maintenance of the COBOL/CICS; RPG / IBM i; and mainframe assembler code	Not applicable	Unknown	Inability to maintain or change the application

9.3 Heat map placement

Each risk from 9.1 is placed on the 5 by 5 grid below (likelihood across, impact up). The application's heat-map position is set by its highest risk, R-014-01 at 20.

Impact 5	5	10	15	20	25
Impact 4	4 / R-014-02, R-014-03	8	12	16	20 / R-014-01
Impact 3	3 / R-014-04	6	9	12	15
Impact 2	2 / R-014-05	4	6	8	10
Impact 1	1	2	3	4	5
	Likelihood 1	Likelihood 2	Likelihood 3	Likelihood 4	Likelihood 5

Shading: red = High (15 to 25), amber = Medium (8 to 14), green = Low (1 to 7). The number in each cell is the risk score.

10. Operational support and IT dependency

This section quantifies the effort required to keep the application running and identifies which activities could shift from IT to business users through configuration, self-service or better tooling.

10.1 Support model

Attribute	Entry
Support team and named contacts	Unknown
Number of staff able to support the application	Unknown
Vendor support arrangement	Unknown
Service level or availability target	Unknown
Change and release process	Unknown

Attribute	Entry
Monitoring and alerting	Unknown

10.2 Support demand (trailing 24 months)

Measure	Value	Source
Incidents logged	Unknown	Service management records not provided
Service requests	Unknown	Service management records not provided
Change requests implemented	Unknown	Service management records not provided
Estimated IT support hours per year	Unknown	Service management records not provided
Estimated business staff hours per year on workarounds	Unknown	Service management records not provided

10.3 Dependency reduction opportunities

Recurring IT activity	Hours per year	Root cause	Opportunity to reduce dependency	Enabler required
Change to hard-coded value: Hard-coded credential: 3_district_aid_lookup.html:8	Unknown	Value held in source code	Move to a business-maintained table	Configuration screen and change controls

10.4 Knowledge concentration

Few people still have COBOL/CICS; RPG / IBM i; and mainframe assembler skills, so the application depends on a small, shrinking pool of staff or vendors. The names of the people who can maintain it today are an open item.

11. User experience

This section evaluates how well the application serves its internal and external users, based on interviews, observation and support history.

11.1 Usability assessment

Dimension	Rating (1 to 5)	Observations
Ease of navigation and task completion	2	Good: warning message uses a cryptic code (AID0142W) and points to another screen (AIDA) by code: 4_aidinq_3270_SCREEN.html (-2 points); screen codes (AID1, AIDA) are cryptic and have no descriptive labels: 4_aidinq_3270_SCREEN.html (-2 points); and 5 smaller issue(s) (-10 points).
Clarity of error messages and validation feedback	Not rated	No evidence in the material reviewed (error handling)
Efficiency for high-volume or repetitive tasks	Not rated	Requires observation of users at work
Consistency with other client applications	Not rated	Requires the portfolio inventory
Mobile and browser compatibility	Not rated	No evidence in the material reviewed (browser support)
Availability of help, guidance and training	Not rated	Not visible in the source
User satisfaction reported in interviews	Not rated	Stakeholder interviews not held

11.2 User experience improvement opportunities

User experience and accessibility are rated 2 (Good): 2 – Good. Usability and accessibility scored 81 out of 100 (weakest file: 3_district_aid_lookup.html, 40). Points were taken off because a form field has no label that a screen reader can announce (6 places, –36 points); text is too faint against its background (2 places, –12 points); an image has no text description (–6 points); and 12 smaller issue(s) (–26 points).

Accessibility (measured against WCAG 2.1 AA, the usual legal standard): a form field has no label that a screen reader can announce (6 places, –36 points); text is too faint against its background (2 places, –12 points); an image has no text description (–6 points); a data table has no header cells (2 places, –4 points); and 4 smaller issue(s) (–8 points).

12. Modernization options and recommendation

This section compares the credible modernization approaches for the application and records the recommended disposition, prioritized by the risk rating in Section 9. Options are described at a planning level and remain vendor and product neutral.

12.1 Disposition options considered

Option	Description	Applicable to this application
Retain	Continue as is with routine maintenance	No: unsupported components must be addressed
Re-host	Move to current infrastructure or cloud without code change	No: moving infrastructure alone does not close the findings in Section 8
Re-platform	Move to a supported platform with limited code change	Yes: recommended
Refactor	Restructure code or architecture while retaining function	Partly: for the debt items in 7.3
Replace	Adopt a commercial, SaaS or shared solution	Not assessed: requires a market review
Consolidate	Merge with other applications into a shared platform	Not assessed: requires the portfolio inventory
Retire	Decommission and move residual function elsewhere	No: the function is still in use

12.2 Options evaluation

Each shortlisted option is scored from 1 (poor) to 5 (strong). Weighted totals: Re-platform 3.40, Refactor 3.55, Retain 1.95. Rationale:

- Re-platform: closes end-of-life and known-vulnerability exposure with targeted code change; keeps proven business logic, so value and debt retired are moderate.
- Refactor: fixes security findings and restructures the worst code on the current platform; retires the most debt short of a rebuild, with moderate disruption.
- Retain: no disruption, but every finding and end-of-life exposure remains open.

Criterion	Weight	Option A: Re-platform	Option B: Refactor	Option C: Retain
Risk reduction (including security and end-of-life exposure)	25%	4	4	1
Business value and user benefit	20%	3	3	2
Technical debt retired	15%	3	4	1
Implementation complexity and disruption	15%	3	3	5

Criterion	Weight	Option A: Re-platform	Option B: Refactor	Option C: Retain
Reduction in IT dependency	10%	3	3	1
Alignment with client enterprise architecture standards	10%	4	4	2
Alignment with industry or peer practice	5%	4	4	2
Weighted total	100%	3.40	3.55	1.95

12.3 Recommendation

Item	Entry
Recommended disposition	Re-platform
Rationale	23% of the code runs on end-of-life or dead-end technology: jQuery 1: end of life Rebuild or move those components (see component dispositions); keep the rest
Consolidation grouping	None identified
Prerequisites	Provide 4 missing component(s); Confirm business criticality
Key risks of the recommended option	Regression in business calculations during change; mitigated by parallel runs against current outputs
Interim risk mitigation until modernized	Encrypt connections; Remove hard-coded credentials; Harden UI security

12.4 Sequencing and timing

Item	Entry
Recommended horizon	Short term, 0 to 12 months
Proposed start window	Unknown
Estimated duration	1–3 months for one developer (4.0–12.5 person-weeks)
Predecessor initiatives	Provide 4 missing component(s); Confirm business criticality
Successor initiatives	None identified
Business blackout periods	Unknown

13. Evidence, open items and sign-off

This section records where each finding came from, what remains unresolved, and the formal acceptance of the report by the client.

13.1 Stakeholder interviews

No stakeholder interviews were held as part of this review; findings rest on the source code, screens and configuration listed in 13.2.

Interview ref	Date	Participants and roles	Organization or unit	Topics covered	Other APP IDs covered
None				Stakeholder interviews were not part of this review	

13.2 Documents and evidence reviewed

Evidence ref	Title or description	Type	Date or version	Location
EV-014-01	1_AIDPAYRN.cbl	Source code	v1, 2026-09-29	Program source set: 1_AIDPAYRN.cbl
EV-014-02	2_AIDPOST.rpgle	Source code	v1, 2026-09-29	Program source set: 2_AIDPOST.rpgle
EV-014-03	3_district_aid_lookup.html	Source code	v1, 2026-09-29	Program source set: 3_district_aid_lookup.html
EV-014-04	4_aidinq_3270_SCREEN.html	Application screen	v1, 2026-09-29	Program source set: 4_aidinq_3270_SCREEN.html
EV-014-05	AIDDBD-live.dbd	Source code	v4, 2026-09-29	Program source set: AIDDBD-live.dbd

13.3 Assumptions and constraints

- Findings reflect the source files listed in 13.2; components not provided are listed in 4.3 and are not scored.
- Business impact defaults to a moderate rating where the business owner has not rated criticality (Section 9).
- Support dates are from published vendor lifecycle information current at the report date.
- Assessment confidence is medium: 96% of referenced code reviewed (4 missing); 1 technology version(s) unconfirmed; business criticality not entered — impact uses defaults.
- No access to production systems, data, service management records or stakeholders was part of this review.

13.4 Open items

Item	Description	Owner	Due date	Status
OI-014-01	Technical reviewer (Section Document control)	Assessment lead	2026-10-29	Open
OI-014-02	Business owner reviewer (Section Document control)	Business owner	2026-10-29	Open
OI-014-03	IT reviewer (Section Document control)	IT	2026-10-29	Open
OI-014-04	Business value or volume supported (Section 1.1)	Business owner	2026-10-29	Open
OI-014-05	Regulatory, contractual or policy basis (Section 2.1)	Business owner	2026-10-29	Open
OI-014-06	Subject matter experts (Section 2.1)	Business owner	2026-10-29	Open
OI-014-07	Year introduced and major rewrites (Section 2.1)	Business owner	2026-10-29	Open
OI-014-08	Known drivers of change (Section 2.1)	Business owner	2026-10-29	Open
OI-014-09	Number of users by group (Section 2.2)	Business owner	2026-10-29	Open
OI-014-10	Swimlane process map with business actors and manual steps (Section 2.3)	Business owner	2026-10-29	Open
OI-014-11	Business pain points in stakeholders' words (interviews) (Section 2.5)	Business owner	2026-10-29	Open
OI-014-12	Deployment model and hosting (Section 3.1)	IT	2026-10-29	Open
OI-014-13	Environments (production, test, development, disaster recovery) (Section 3.1)	IT	2026-10-29	Open
OI-014-14	Source code repository and version control (Section 3.1)	IT	2026-10-29	Open
OI-014-15	Web and application server and version (Section 3.2)	IT	2026-10-29	Open
OI-014-16	Identity and authentication and version (Section 3.2)	IT	2026-10-29	Open
OI-014-17	Infrastructure and version (Section 3.2)	IT	2026-10-29	Open
OI-014-18	Licensing and contracts for commercial products (Section 3.3)	IT	2026-10-29	Open
OI-014-19	Deployment (physical) architecture: servers, environments, network zones (Section 4.1)	IT	2026-10-29	Open
OI-014-20	Frequency, owner and failure handling of each interface in 4.2 (Section 4.2)	IT	2026-10-29	Open
OI-014-21	Downstream systems (Section 4.3)	IT	2026-10-29	Open
OI-014-22	Data volumes, retention requirements and system-of-record status (5.1) (Section 5.1)	Business owner	2026-10-29	Open
OI-014-23	Data quality ratings (requires production data) (Section 5.2)	Business owner	2026-10-29	Open
OI-014-24	Release, deployment and environment practices (Section 7.4)	IT	2026-10-29	Open
OI-014-25	Security control: authorization (Section 8.1)	Information security	2026-10-29	Open
OI-014-26	Security control: privileged (Section 8.1)	Information security	2026-10-29	Open

Item	Description	Owner	Due date	Status
OI-014-27	Security control: audit logging (Section 8.1)	Information security	2026-10-29	Open
OI-014-28	Security control: secure development (Section 8.1)	Information security	2026-10-29	Open
OI-014-29	Security control: backup (Section 8.1)	Information security	2026-10-29	Open
OI-014-30	Compensating controls for unsupported components (Section 8.4)	Information security	2026-10-29	Open
OI-014-31	Client security policy and standards (Section 8.5)	Information security	2026-10-29	Open
OI-014-32	Maximum tolerable outage and current workarounds (9.2) (Section 9.2)	Business owner	2026-10-29	Open
OI-014-33	Support team and named contacts (Section 10.1)	IT	2026-10-29	Open
OI-014-34	Number of staff able to support (Section 10.1)	IT	2026-10-29	Open
OI-014-35	Vendor support arrangement (Section 10.1)	IT	2026-10-29	Open
OI-014-36	Service level or availability target (Section 10.1)	IT	2026-10-29	Open
OI-014-37	Change and release process (Section 10.1)	IT	2026-10-29	Open
OI-014-38	Monitoring and alerting (Section 10.1)	IT	2026-10-29	Open
OI-014-39	Support demand for the trailing 24 months (10.2) (Section 10.2)	IT	2026-10-29	Open
OI-014-40	Individuals holding key knowledge of the application (Section 10.4)	IT	2026-10-29	Open
OI-014-41	Proposed start window (fiscal year and quarter) (Section 12.4)	Business owner	2026-10-29	Open
OI-014-42	Business blackout periods (Section 12.4)	Business owner	2026-10-29	Open
OI-014-43	Stakeholder interviews (Section 13.1)	Assessment lead	2026-10-29	Open
OI-014-44	Provide the source of program AIDRPT (referenced but not provided) (Section 4.3)	IT	2026-10-29	Open
OI-014-45	Provide the source of screen AIDDSP (referenced but not provided) (Section 4.3)	IT	2026-10-29	Open
OI-014-46	Provide the source of screen AIDSCR (referenced but not provided) (Section 4.3)	IT	2026-10-29	Open

13.5 Review and acceptance

Role	Name	Organization	Decision	Date
Assessment lead	Ledelsea Assessment Team	Ledelsea	Submitted	2026-09-29
Business owner		Example State Agency		

Role	Name	Organization	Decision	Date
IT application or architecture lead		Example State Agency		
Information security reviewer		Example State Agency		
Client project manager		Example State Agency		

13.6 Appendices

- **Appendix A: Architecture diagrams in editable Visio (.vsdx) and draw.io formats, supplied with this report**
- **Appendix B: Technology and component inventory (Sections 3.2 and 6.2)**
- **Appendix C: Technical debt detail (Section 7.3)**
- **Appendix D: Restricted security findings, supplied separately to named security staff**
- **Appendix E: Screen flow (Figure 2)**
- **Appendix F: Report catalog (Section 5.3)**
- **Appendix G: Glossary of technical terms (below)**

Appendix G. Glossary

Term	Meaning
3270	The IBM mainframe terminal ('green screen') format.
CICS	IBM's mainframe system for online (screen-based) transactions.
COBOL	A business programming language from 1959, still widely used on mainframes.
CVE	Common Vulnerabilities and Exposures: the public list of known security weaknesses in software.
CVSS	Common Vulnerability Scoring System: a 0–10 severity score for a known weakness.
CWE	Common Weakness Enumeration: the standard catalogue of kinds of software weakness.
Cyclomatic complexity	The number of independent paths through a routine; higher means harder to test.
End of life	The vendor has stopped releasing fixes, including security fixes.
Hard-coded credential	A password or key written into the code itself.
HTTPS	The encrypted version of HTTP, the protocol web pages use.
IBM i	IBM's midrange operating system (formerly AS/400).
IMS	IBM's hierarchical mainframe database and transaction manager.
jQuery	A widely used JavaScript library for web pages.
MFA	Multi-factor authentication: signing in with a second proof such as a phone code.
Mixed content	An HTTPS page that loads some parts over unencrypted HTTP.
NIST SP 800-53	The US government catalogue of security and privacy controls.
Personal data	Information that identifies a person (names, identifiers, contact details).
Re-host	Move to new infrastructure or cloud without changing the code.

Term	Meaning
Re-platform	Move to supported versions of the platform with limited code change.
Refactor	Restructure the code without changing what it does.
RPG	A business programming language for IBM i (AS/400) midrange systems.
Technical debt	Shortcuts and outdated code that make every future change slower and riskier.
TLS	Transport Layer Security: the encryption behind HTTPS.
WCAG	Web Content Accessibility Guidelines: the international standard for accessible web content (2.1 AA is the usual target).
XSS	Cross-site scripting: an attacker's script runs in a user's browser through a vulnerable page.